

Ransomware Attack Paralyzes Pathology Services in the UK's National Health Service

Ransomware is a type of malicious software or malware that blocks or limits access to a computer or network by encrypting the files on it, after which the cybercriminal responsible demands a ransom payment, typically in the form of a cryptocurrency such as Bitcoin, in exchange for the decryption key. According to Statista, there were well over 300 million ransomware attempts across the world in 2023 alone. In June 2024, a major ransomware attack paralyzed critical pathology services across multiple hospitals within the United Kingdom's National Health Service (NHS) as well as general practice (GP) services that deliver the NHS's primary care in communities across several sites in the country.

Synnovis is a partnership between Guy's and St. Thomas' NHS Foundation Trust, the King's College Hospitals NHS Trust, and SYNLAB. It provides a range of pathology services, including diagnostics, testing, and digital pathology, to several NHS hospitals. As a key response to a major review that found NHS pathology services to be fragmented and inefficient, Synnovis was tasked with the creation of an integrated "hub and spoke" pathology network for South East London.

On June 3, 2024, Synnovis was subjected to a ransomware attack that crippled pathology services in several hospitals and GP practices across this subregion. The attack led to the cancellation of thousands of clinical appointments and operations, including emergency procedures such as cancer surgeries and organ transplants. The attack was reported to have originated from the Qilin cybercrime group, which has been implicated in several such incidents. The group provides ransomware-as-a-service (RaaS), a cybercrime business model where ransomware code is provided to affiliates in return for a portion of any ransom payment.

Qilin has claimed that it used a "zero-day vulnerability"—an unknown software vulnerability for which vendors have "zero days" to develop a fix, as the vulnerability has already been exploited by malicious actors—to infiltrate Synnovis's IT systems, lock their computers, and encrypt their data. The attackers soon published 400GB of encrypted data files, which included sensitive NHS patient data as well as details of Synnovis's financial arrangements with hospitals and GP services.

Synnovis responded to the attack by establishing workarounds involving the manual processing of medical samples, which led to significant delays and reduced capacity. It also had to rebuild more than 60 different core IT systems used within its laboratories. To understand the reasons and full implications of the data breach, the company appointed an IT taskforce to work with cybercrime experts from the NHS and liaise with the UK's National Cyber Security Centre (NCSC) and NHS England's cyber operations team. Pathology services were disrupted for months after the attack, with Synnovis gradually restoring services based on clinical priority. NHS England reported that most pathology services were fully restored by October 2024.

Healthcare organizations are particularly vulnerable to cyberattacks because of the critical functions they perform, the vast quantities of data they process and store, and the outdated IT infrastructures prevalent in many cash-starved public hospitals. Globally, ransomware attacks against the healthcare sector rose from 214 in 2022 to 389 in 2023. The NHS is no stranger to such attacks; in 2017, it was the target of the worldwide WannaCry ransomware attack, which caused the cancellation of 19,000 patient appointments, and another attack in 2022 brought down the non-emergency 111 service. SYNLAB too had previously been victim to two cyberattacks against its facilities in Italy and France. According to a former head of the UK's NCSC, outdated IT infrastructure, the need to identify points of vulnerability, and the importance of basic security practices are the key challenges facing the NHS. These are pressing issues given the increasing digitalization of healthcare services within the organization.

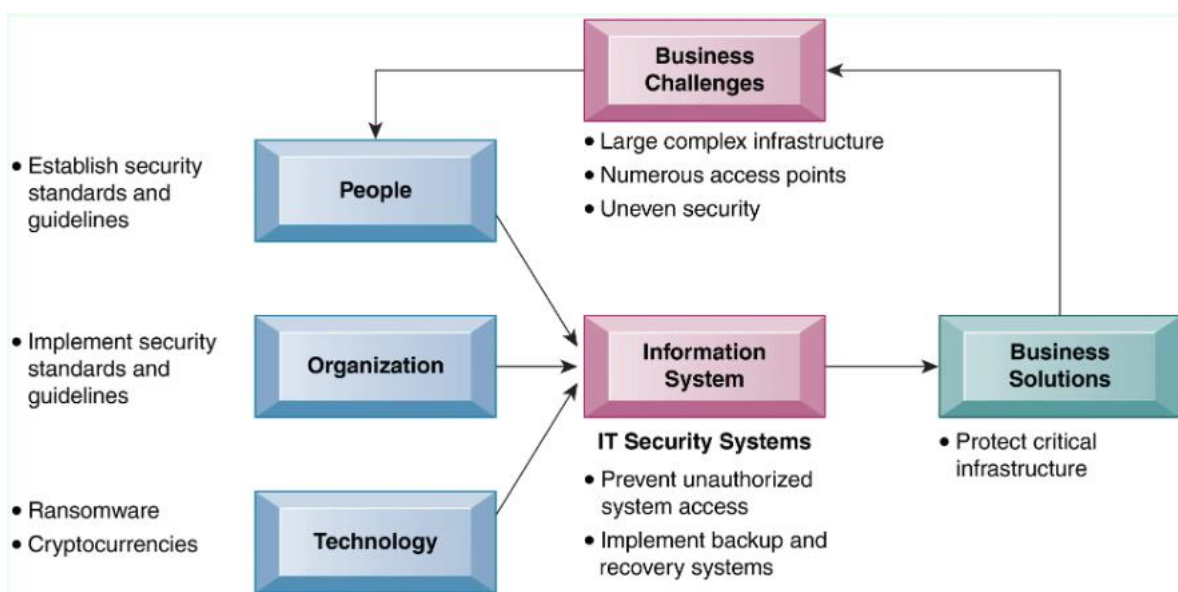
There are numerous lessons to be learned from the Synnovis ransomware attack. Outdated IT systems in healthcare organizations such as the NHS need upgrading to keep pace with rapidly emerging threats.

Maintaining backups of critical patient data can help organizations like Synnovis replace lost records and ensure patient safety. But given the complex supply chains that are central to the NHS and similar healthcare providers, even the most stringent cybersecurity measures taken by individual providers are inadequate if their partners and suppliers do not follow similar security protocols, and this appears to have been the case with Synnovis. Major causes for such attacks are human vulnerabilities, such as employees clicking on suspicious email links and data breaches by staff.

In response to the Synnovis cyberattack, the UK government announced plans for legislation to strengthen regulatory powers to investigate potential digital vulnerabilities and to enhance cybersecurity measures and reporting requirements for private organizations that provide services to the public sector. Given the increasing threats from cybercriminals and the vulnerability of healthcare organizations, more cyber resilience strategies are needed to keep patients safe from cyberattacks within the healthcare sector.

Sources

The Synnovis cyberattack highlights the critical importance of cybersecurity for organizations, particularly those that deal with confidential data. The IT security vulnerabilities that led to the cyberattack on Synnovis illustrate the potential for data theft and disruption to critical public and private infrastructure, which can last weeks if not months, paralyzing business, government functions, and daily life. Poor IT security protocols result in billions of dollars' worth of losses annually for businesses and consumers.



The Opening Case Study diagram above calls attention to important points raised by this case and this chapter. Organizations that lack or fail to effectively implement security awareness, resources, and tools create significant risk not only for their own organizations but also for their customers and society at large.

CASE STUDY QUESTIONS

What management, organization, and technology factors were responsible for the Synnovis cyberattack?

In what ways did the impact of the Synnovis cyberattack extend beyond its immediate clients?

How could the ransomware attack against Synnovis have been prevented?

Case study contributed by G. "Hari" Harindranath, Royal Holloway University of London